

Alumna: Nahomy Dafne Cante Jiménez
Lunes 31 de agosto del 2026
Análisis y planificación del pentest

Caso: Aurora Market

Empresa mexicana de comercio electrónico en una aplicación web.

Objetivo

1. Comprobar la existencia de fallos de control de acceso (IDOR) en las URL o a través de las peticiones web, manipulando la interfaz y los parámetros numéricos de navegación.
2. Localizar la información de los perfiles que es visible (datos personales, historial de compras y métodos de pago) y determinar el nivel de sensibilidad en caso de que un atacante explote algún fallo.
3. Verificar que, dentro de las medidas de seguridad en el backend de la aplicación web, se valide la autorización de los usuarios por cada consulta, comprobando que poseen permisos legítimos sobre el recurso solicitado antes de mostrar cualquier dato en la pantalla.

Alcance

Sí se evaluará

- Aplicación web.

NO se evaluará

- Redes sociales de la empresa.
- Dispositivos del personal interno.
- Cuentas de correo electrónico asociadas.
- Proveedores externos.
- Sistemas vinculados.

Permisos y condiciones

Permisos requeridos

- Autorización formal para realizar la prueba de pentest en la aplicación web.
- Conocimiento de la información parcial proporcionada sobre la infraestructura (se reconoce por parte de su equipo la existencia de los mecanismos de autenticación, los tipos de usuarios y una base de datos).

Condiciones acordadas

- No interrumpir deliberadamente el funcionamiento de la plataforma.
- No afectar la información real de los clientes.
- Realizar las pruebas durante horarios de menor actividad para reducir cualquier posible impacto sobre sus operaciones.
- Entregar documento detallado para revisión del equipo de desarrollo que incluya la identificación de los riesgos existentes, el análisis de sus posibles afectaciones y la sugerencia de medidas que deben tomarse para la reducción de los mismos.

Metodología

Tipo de Pentest

Gray-box

Este enfoque permitiría simular la lógica del negocio mediante el acceso con credenciales, con la intención de manipular los permisos y las peticiones de la plataforma para escalar privilegios hasta ver datos ajenos del usuario. Esta gestión de las sesiones lograría verificar cuándo el sistema aísla correctamente la información entre los diferentes tipos de usuarios.

Además, una de las condiciones previamente señaladas es que no se entregará toda la información técnica de la infraestructura, a sabiendas de que se desconocen todos los detalles sobre cómo está construida la plataforma y la tecnología que utiliza, por lo que la opción del tipo white-box que se adentra a conocer el sistema no es viable. Y la del tipo black-box impediría cumplir con los objetivos establecidos.

Modelo

Open Web Application Security Project (OWASP)

En razón de que este modelo funciona como la guía de referencia mundial para la seguridad en aplicaciones web y de APIs, lo que lo vuelve adecuado para el comercio electrónico. Entre sus entradas se encuentra el caso específico de IDOR, dentro de la categoría de **Broken Access Control**, relacionada con los controles de autenticación, la gestión de sesiones y las pruebas de control de acceso.

Recopilación de información previa

Estado de la materialidad

1. Plataforma web destinada al comercio electrónico que cuenta con varias funcionalidades para sus usuarios: registro, consulta de productos, efectuar compras y revisión del estado del pedido.
2. La interfaz de accesos restringidos y controlados para el personal autorizado encargado de la administración del inventario, la atención a usuarios y el seguimiento de los pedidos.

ACTIVIDAD 01 - ETHICAL HACKING - HACKER WOMEN 2026

3. El sistema procesa y almacena información de carácter personal y transaccional, incluyendo datos de contacto (nombre, correo electrónico, teléfono), direcciones de envío e historial detallado de compras.

Revisión del caso

1. **Reporte de usuario sin evidencia suficiente:** asegura haber visto información que aparentemente pertenecía a otro usuario.
2. No se ha hecho una evaluación formal de seguridad previamente.

Recursos necesarios

- Credenciales de acceso / cuentas de usuario de prueba (mínimo 2 para alternar los accesos y contrastar el cruce de información entre ellos).
- Navegador web para rutear el tráfico con proxy de interceptación para encontrar vulnerabilidades a partir de las peticiones HTTP y HTTPS que se envían al servidor (tal como OWASP ZAP).
- Acuerdo operativo que defina explícitamente los objetivos de ejecución, sus fechas y horarios, además de los canales de notificación y emergencia con el equipo designado de la empresa.
- Herramienta de documentación y control de versiones (GitHub).

Programación del Pentest

1. Reconocimiento (Día 1-2)

Análisis del comportamiento de la aplicación usando cuentas de prueba facilitadas (perfiles de usuario normal y administrador) para entender cómo viaja la información.

2. Análisis de vulnerabilidades (Día 3-4)

Mapeo de todas las direcciones web (URLs) y botones donde se envían números de identificación (como el número de un usuario, de una compra o de un producto) para identificar por dónde empezar las pruebas.

Desde esta etapa se apoya en el Modelo de OWASP para enfocar las pruebas de los riesgos web más críticos, específicamente el control de acceso roto (IDOR), la manipulación de parámetros y la validación de permisos en el backend.

3. Explotación (Día 5-7)

Prueba controlada cambiando los números en las direcciones web o en los mensajes que manda la página (intentando ver si el sistema te deja ver información de otras personas cambiando solo un número, conocido como IDOR).

4. Post-explotación (Día 8)

Medición del daño real: verificar exactamente qué tan privados son los datos expuestos (historiales, tarjetas, datos personales) si un intruso logra saltarse los controles.

5. Informe (Día 9-10)

Entrega del reporte final con los hallazgos explicando los riesgos, sus afectaciones al negocio y cómo solucionarlos en el sistema, acompañado de una junta de presentación. Contraste y complementación del documento de Análisis de Riesgo Preventivo.

Anexo

Análisis de Riesgo Preventivo

- **Control de Acceso Roto (IDOR):**
 - *Riesgo:* que la manipulación de parámetros numéricos en las peticiones web permita acceder a los recursos de otros usuarios.
 - *Afectación:* robo masivo de cuentas y usurpación de identidad mediante la exposición de perfiles ajenos.
 - *Medidas:* validar la propiedad de los datos en el servidor antes de responder y utilizar identificadores aleatorios en lugar de secuencias numéricas predecibles.
- **Exposición de Información Sensible:**
 - *Riesgo:* que el sistema entregue a la pantalla datos privados de perfiles, historiales de compra y métodos de pago sin la debida protección.
 - *Afectación:* pérdida de confianza de los clientes, multas por incumplimiento normativo y riesgos de fraude financiero.
 - *Medidas:* programar el servidor para enviar únicamente los datos indispensables y aplicar enmascaramiento a la información financiera o delicada.
- **Falta de Verificación en el Backend:**
 - *Riesgo:* que la seguridad dependa únicamente de ocultar elementos en la interfaz visual, permitiendo peticiones directas al servidor.
 - *Afectación:* acceso no autorizado a funciones administrativas y áreas restringidas del sistema.
 - *Medidas:* implementar una regla de "denegar por defecto" en el servidor y centralizar la validación de permisos legítimos para cada consulta realizada.